

MÓDULO 8: SEGURIDAD

CRYPTOGRAPHIC FAILURES

OWASP TOP 10

BIG school

GENERAMOS
NEGOCIO

BIGSEO

Fallas Criptográficas

Índice

- ¿Qué vamos a ver?
- ¿Qué es Cryptographic Failures?
- ¿En qué consiste?
- Ejemplos típicos
- ¿Qué puede hacer alguien que explote fallas criptográficas?
- ¿Cómo detectarlas?
- ¿Cómo prevenirlo?
- ¿Cómo mitigarlo en producción?
- Checklist rápido
- Conclusiones

Fallas Criptográficas

BIG school

BIGSEIO

GENERAMOS
NEGOCIO

¿Qué vamos a ver?

- Vulnerabilidad que abarca el uso indebido de la criptografía.
- Desde algoritmos obsoletos hasta mala gestión de claves.
- Veremos qué son, ejemplos, impacto, detección y prevención.

¿Qué es Cryptographic

Failures?

es el uso, configuración o gestión de mecanismos criptográficos.

- No basta con cifrar: importa hacerlo bien.
- Protegen confidencialidad, integridad y autenticidad.
- Cuando cualquiera falla, los datos quedan expuestos o manipulables.

¿En qué consiste?

- Algoritmos obsoletos (MD5, SHA-1, DES, RC4).
- Cifrado sin autenticación ni verificación.
- Claves incrustadas o sin rotación.
- Hashing débil o sin sal en contraseñas.
- Transporte sin TLS o con certificados inválidos.
- Archivos y dependencias sin verificar.
- Secretos almacenados en lugares inseguros.

Ejemplos típicos

- Contraseñas en texto plano o con hash débil.
- Cifrado simétrico sin autenticación.
- Claves o tokens expuestos en el repositorio.
- TLS mal configurado o sin verificación.
- Dependencias sin firma o sin control de integridad.

¿Qué puede hacer alguien que explote fallas criptográficas?

- Robo de credenciales y acceso no autorizado.
- Exposición de datos personales o financieros.
- Manipulación de información sin detección.
- Interceptación de comunicaciones (MITM).
- Compromiso de pipelines o artefactos firmados.
- Se afecta confidencialidad, integridad y autenticidad.

¿Cómo detectarlas?

Durante el desarrollo:

- Detectar algoritmos obsoletos y claves expuestas.
- Revisar dependencias y configuraciones criptográficas.
- Usar herramientas SAST y análisis de repositorios.
- Validar que TLS sea obligatorio.

En auditorías:

- Revisar versiones TLS, buscar secretos en repositorios, verificar firmas digitales de artefactos.

En producción:

- Monitorear KMS, verificar errores criptográficos constantes, patrones anómalos y certificados caducados.

¿Cómo prevenirlo?

Principios de diseño:

- No reinventar, usar librerías probadas.
- Cifrar en tránsito y en reposo.
- Restringir acceso a claves (mínimo privilegio).
- Negar acceso ante fallas criptográficas.

Buenas prácticas:

- Hash seguro (Argon2, bcrypt, PBKDF2) con salt único.
- Modos de cifrado autenticado (AES-GCM, ChaCha20-Poly1305).
- Forzar TLS 1.2 o superior y validar certificados.
- Guardar claves en gestores seguros (Vault, KMS) y rotarlas.
- Firmar artefactos y verificar integridad.
- Mantener librerías actualizadas.

¿Cómo mitigarlo en producción?

- Identificar datos y alcance comprometido.
- Rotar claves y secretos de inmediato.
- Invalidar tokens y sesiones derivadas.
- Actualizar librerías y aplicar parches.
- Auditar accesos y registrar incidentes.
- Incorporar controles compensatorios (MFA, cifrado adicional).
- Cumplir normativas de notificación y documentar el proceso.

Checklist rápido

1. ¿Usas algoritmos modernos y seguros?
2. ¿No hay claves ni contraseñas en el código?
3. ¿TLS 1.2/1.3 está activo y validado?
4. ¿El cifrado es autenticado y los IVs únicos?
5. ¿Las contraseñas usan hashing seguro con sal?
6. ¿Los artefactos están firmados y verificados?
7. ¿Rotas claves periódicamente y auditas accesos?

Conclusiones

1. Una falla criptográfica es invisible hasta que causa daño.
2. No basta cifrar: hay que hacerlo bien y mantenerlo seguro.
3. Revisa tus proyectos, elimina secretos del código y aplica TLS.

Cada pequeña mejora fortalece todo el ecosistema